Aspectos sociales de la ciberseguridad

Examen de práctica — Primer parcial · Unidad 1: Comportamiento humano · Unidad 2: Gestión de identidad

Nombre: _____ Fecha: _____ Calificación: _____

Instrucciones generales: lee con atención cada reactivo. En las preguntas abiertas se califica la **argumentación**: no basta con enumerar conceptos, explica *por qué*. Tiempo sugerido: 90 minutos. La clave de respuestas está al final; no la consultes hasta terminar.

Sección	I. Opción múltiple	II. Verdadero / Falso	III. Relación	IV. Respuesta corta	V. Preguntas abiertas	Total
Valor	40	10	10	10	30	**100**
Obtenido						

I. Opción múltiple (20 reactivos × 2 pts = 40 pts)

Encierra en un círculo la letra de la respuesta correcta.

1. ¿Cuántas áreas de conocimiento define el CyBOK (*Cyber Security Body of Knowledge*)?
   a) 5 b) 14
   c) 21 d) 9

2. «Un sistema seguro debe ser fácil de usar y no debe exigir tensión mental ni el conocimiento de una larga serie de reglas». ¿De quién es este principio y de qué año?
   a) Saltzer y Schroeder, 1975 b) Auguste Kerckhoffs, 1883
   c) James Reason, 1990 d) BJ Fogg, 2009

3. Según Saltzer y Schroeder (1975), el principio que dice que *superar una medida debe costarle al atacante más de lo que gana* se conoce como:
   a) Psicología b) Factores humanos
   c) Economía del crimen d) Mínimo privilegio

4. De acuerdo con la ISO 9241-11:2018, los «recursos empleados en relación con la exactitud e integridad con que se alcanzan los objetivos» corresponden a la:
   a) Eficacia b) Eficiencia
   c) Satisfacción d) Accesibilidad

5. La respuesta tradicional de «concienciar y educar» busca adaptar al ser humano a la tarea. ¿Qué propone la seguridad usable?
   a) Sancionar a quien incumpla la política de seguridad
   b) Adaptar la tarea al ser humano
   c) Sustituir al usuario por controles automáticos
   d) Aumentar el número de mecanismos de seguridad distintos

6. Dentro de la clasificación de tareas, las tareas de seguridad (por ejemplo, restablecer una contraseña) se consideran tareas:
   a) Primarias b) De producción
   c) Habilitadoras d) Latentes

7. Un empleado anota sus contraseñas y usa un *mouse jiggler* para que su sesión no se bloquee. Esto es un ejemplo de:
   a) Fatiga de seguridad
   b) Sesgo de anclaje
   c) Heurística afectiva
   d) Movimiento lateral

8. Según James Reason, un **fallo latente** es:
   a) Una violación directa de un procedimiento por parte de una persona
   b) Una condición de la organización o del lugar de trabajo, como el conflicto entre la tarea principal y la de seguridad
   c) Un error aleatorio e impredecible
   d) Una vulnerabilidad de software sin parchar

9. En el modelo del queso suizo, los agujeros de las rebanadas representan:
   a) Los atacantes que intentan entrar
   b) Las defensas (mecanismos y políticas)
   c) Las fallas latentes y activas
   d) Los cuasi accidentes ya notificados

10. Según el enfoque de Daniel Kahneman, los expertos afirman que, sin considerar la productividad:
    a) Modo rápido = modo seguro
    b) Modo lento = modo seguro
    c) Ningún modo es seguro
    d) Ambos modos son igual de seguros

11. En el modelo de Fogg, el comportamiento resulta de:
    a) Conocimiento + actitud + sanción
    b) Motivación + capacidad + disparador (*prompt*)
    c) Concienciación + educación + formación
    d) Confianza + roles + cumplimiento

12. ¿Qué modelo mental de seguridad tiene como limitación principal que **quita la responsabilidad individual** («que se encarguen los expertos») y usa el miedo?
    a) Seguridad física
    b) Médico
    c) Guerra
    d) Económico

13. El gusano **Blaster** y el «gusano bueno» **worm_blastMS** se usan para ilustrar el modelo mental:
    a) Médico
    b) De guerra
    c) De seguridad física
    d) De mercado

14. Durante una brecha, el equipo de defensa concentra toda la remediación en el primer vector descubierto (un RDP expuesto) e ignora que el atacante ya estableció persistencia por otros medios. ¿Qué sesgo es?
    a) Confirmación
    b) Anclaje
    c) Dunning-Kruger
    d) Comportamiento gregario

15. Un administrador junior recibe un correo urgente «del CEO» pidiendo una transferencia y se salta la verificación. El sesgo explotado en este ataque BEC es:
    a) Efecto de autoridad
    b) Sesgo de optimismo
    c) Agotamiento del ego
    d) Racionalidad limitada

16. El orden correcto de las fases del ciclo de vida de la identidad es:
    a) Joiner, Leaver, Mover
    b) Mover, Joiner, Leaver
    c) Joiner, Mover, Leaver
    d) Leaver, Mover, Joiner

17. Una contraseña de un solo uso (OTP) es un factor de:
    a) Conocimiento
    b) Posesión
    c) Inherencia
    d) Comportamiento

18. El algoritmo **TOTP** genera el código a partir de:
    a) Un HMAC y un contador de solicitudes
    b) La hora actual y un secreto compartido
    c) La huella digital del usuario
    d) El IMEI asociado a la SIM

19. Sobre OpenID Connect (OIDC) es correcto afirmar que:
    a) Sirve para autorización y su token clave es el de acceso
    b) Sustituye por completo a OAuth 2.0
    c) Sirve para autenticación, usa un token de identidad (ID) y va encima de OAuth 2.0
    d) Es un protocolo de directorio que usa el puerto 389

20. ¿Qué documento define la arquitectura de Confianza Cero (*Zero Trust*)?
    a) ISO 9241-11
    b) NIST SP 800-207
    c) CyBOK v1.1
    d) FIDO2

II. Verdadero o falso (10 reactivos × 1 pt = 10 pts)

Escribe V si el enunciado es verdadero o F si es falso. Si es falso, corrígelo en una línea (no da puntos extra, pero te sirve para estudiar).

( ) Los sesgos cognitivos pueden eliminarse ofreciendo incentivos y con suficiente educación.

( ) La ciberhigiene incluye prácticas regulares para mantener la salud y seguridad de usuarios, dispositivos, redes y datos, y también para recuperarse de un ataque.

( ) Según Douglas MacArthur, si una política de seguridad no se cumple porque es imposible de cumplir, se debe endurecer la sanción.

( ) En FIDO2 / *passkeys*, el servicio almacena la clave privada del usuario y el dispositivo guarda la pública.

( ) La MFA por SMS es la opción más recomendada porque el SMS viaja cifrado.

( ) En Zero Trust, el acceso a los recursos se concede por sesión y con una política dinámica.

( ) Con Kerberos, en la red viajan tickets de duración limitada en lugar de contraseñas.

( ) HOTP cambia cada 30 a 60 segundos.

( ) Las simulaciones antiphishing miden y enseñan, pero pueden minar la confianza del personal en la organización.

( ) Un certificado *wildcard* sirve para proteger dominios distintos, como miempresa.com y tienda.miempresa.es.

III. Relación de columnas (10 reactivos × 1 pt = 10 pts)

Escribe en el paréntesis la letra de la columna B que corresponde a cada elemento de la columna A.

A) Sesgos cognitivos

( )	1. Heurística afectiva	a) «Ya destruí los documentos confidenciales», y luego hace clic en el phishing.
( )	2. Comportamiento gregario	b) La fuerza de voluntad se agota: sin recordatorios se pierde el hábito.
( )	3. Fatiga por toma de decisiones	c) Si algo da buena impresión, se percibe de bajo riesgo.
( )	4. Efecto de la autoconfianza	d) Si un grupo pega contraseñas en *post-its*, la práctica se contagia.
( )	5. Agotamiento del ego	e) Hay tantas alertas que se terminan ignorando.

B) Tipos de certificado digital

( )	6. Firma de código	f) Firmar y cifrar correo corporativo confidencial.
( )	7. S/MIME	g) Validación rigurosa de la organización (entidad financiera, gobierno).
( )	8. De cliente	h) Comprobar que una actualización de Windows no fue alterada.
( )	9. EV	i) Todos los subdominios: `*.miempresa.com`.
( )	10. *Wildcard*	j) Autenticar a un usuario o máquina ante el servidor (VPN empresarial).

IV. Respuesta corta (5 reactivos × 2 pts = 10 pts)

1. Menciona las **4 características** de las ilusiones cognitivas (sesgos).

2. Menciona los **4 factores** que se deben considerar para adaptar la tarea al ser humano.

3. Menciona los **4 pilares** de la IAM y qué hace cada uno (una línea por pilar).

4. Menciona los **7 requisitos** de un método biométrico.

5. ¿En qué consiste la **fatiga MFA** (bombardeo MFA) y qué método de autenticación es vulnerable a ella?

V. Preguntas abiertas (5 preguntas × 6 pts = 30 pts)

Responde con argumentos completos. Se califica que uses los conceptos del curso y que expliques el porqué.

1. Explica la diferencia entre **identificación, autenticación y autorización**. Ilústrala con un ejemplo de un alumno que entra a la plataforma de su universidad y menciona qué control de acceso (RBAC o ABAC) usarías y por qué. **6 pts**

2. **6 pts**

> En una empresa contable, en plena temporada de declaraciones, una auxiliar que lleva 10 horas trabajando hace clic en un correo de phishing. La capacitación de seguridad fue una presentación de diapositivas hace un año, el filtro de correo tenía una regla desactivada «temporalmente» y la política exige cambiar la contraseña cada 15 días. El director quiere despedirla.

Analiza el caso con el **modelo del queso suizo**: identifica el fallo activo y al menos tres fallos latentes (clasificándolos como individuales, humanos, de la tarea o del ambiente de trabajo). Argumenta si despedirla resuelve el problema y propone dos medidas.

3. Debes diseñar una campaña de concienciación para **adultos mayores que usan la banca en línea**. ¿Qué **modelo mental** (seguridad física, médico, guerra o económico) usarías y por qué? Menciona una limitación del modelo que elegiste y por qué descartas al menos uno de los otros. **6 pts**

4. ¿Por qué un empleado que **sabe** que no debe reutilizar contraseñas lo sigue haciendo? Argumenta usando al menos tres de estos conceptos: fatiga de seguridad, tarea habilitadora vs de producción, memoria de largo plazo, modelo de Fogg, sesgo de optimismo, agotamiento del ego. Propón una solución basada en la seguridad usable. **6 pts**

5. **6 pts**

> Una empresa mediana tiene toda su red en una sola VLAN plana porque «nuestra red no es un objetivo interesante». Usa MFA por SMS. Una auditoría encontró cuentas de tres extrabajadores aún activas, una de ellas con privilegios de administrador, y que todos los empleados de ventas tienen acceso a la configuración del firewall.

Identifica al menos **cuatro riesgos** (incluye el sesgo cognitivo presente y los vectores de ataque que se habilitan) y propone una estrategia de mitigación justificada usando conceptos de la Unidad 2 (Zero Trust, JML, RBAC/ABAC, autenticación, ISPM).

Clave de respuestas

Revísala después de terminar. Las respuestas de la sección V son guías: cualquier argumentación equivalente vale.

I. Opción múltiple

1. c	2. b	3. c	4. b	5. b
6. c	7. a	8. b	9. c	10. b
11. b	12. c	13. a	14. b	15. a
16. c	17. b	18. b	19. c	20. b

Notas: (8) la opción a es un fallo *activo*. (9) Las rebanadas son las defensas; los agujeros, las fallas. (18) La opción a describe HOTP. (19) La opción a describe OAuth 2.0; la d, LDAP.

II. Verdadero o falso

1. **F**. Los sesgos son sistemáticos, involuntarios y difíciles de evitar; no se eliminan con incentivos ni con educación. Se diseñan controles a su alrededor.
2. **V**. Definición de Irel (2023).
3. **F**. «Nunca emitas una política de seguridad que no se pueda cumplir»: si es imposible de cumplir, se **rediseña**.
4. **F**. Es al revés: el servicio tiene la clave **pública**; la **privada** nunca sale del dispositivo y se protege con un PIN o biometría.
5. **F**. El SMS no va cifrado y es vulnerable al SIM swapping. Se recomiendan *passkeys* FIDO con llave física.
6. **V**. Es uno de los principios de NIST SP 800-207.
7. **V**.
8. **F**. Eso es TOTP. HOTP cambia cada vez que se solicita (HMAC + contador).
9. **V**. Es el riesgo del «auto ataque».
10. **F**. Eso es un certificado SAN o multidominio; el *wildcard* cubre los subdominios (`*.miempresa.com`).

III. Relación de columnas

1. c	2. d	3. e	4. a	5. b
6. h	7. f	8. j	9. g	10. i

IV. Respuesta corta

1. a) Difieren de la realidad; b) se desvían **sistemáticamente** (no al azar); c) son **involuntarias**; d) son **difíciles de evitar**.
2. Capacidades y limitaciones del usuario; objetivos y tareas; contexto físico y social; capacidades del dispositivo.
3. **Administración**: crear, mantener y eliminar identidades. **Autenticación**: verificar que el usuario es quien dice ser. **Autorización**: dar el nivel de acceso adecuado (RBAC, mínimo privilegio). **Auditoría**: registrar qué hace cada quien con sus permisos.
4. Universalidad, singularidad, permanencia, coleccionabilidad, rendimiento, aceptabilidad y elusión (que no sea fácil engañarlo).
5. El atacante, que ya tiene la contraseña, envía solicitudes de aprobación una y otra vez hasta que la víctima acepta por error o por cansancio. Es vulnerable la autenticación por notificación **push**.

V. Preguntas abiertas: puntos que debe incluir la respuesta

1. **Identificación**: decir quién eres (el alumno escribe su matrícula o usuario). **Autenticación**: demostrarlo con un factor (contraseña = conocimiento; OTP o *passkey* = posesión; huella = inherencia). **Autorización**: qué puede hacer ya verificado (ver sus calificaciones, pero no modificarlas). RBAC si basta con el rol (alumno, docente, administrativo); ABAC si conviene decidir por atributos (por ejemplo, solo puede inscribir materias en el periodo de inscripción o desde cierta ubicación). Mencionar el mínimo privilegio.
2. **Fallo activo**: el clic. **Fallos latentes**: fatiga tras 10 horas (individual); presión de tiempo y carga alta por la temporada (de la tarea); capacitación sin práctica ni refuerzo (formación deficiente, del ambiente o de la organización); regla del filtro desactivada (defensa técnica con agujero, ambiente de trabajo); política de contraseñas casi imposible de cumplir (MacArthur), que genera resentimiento y contraseñas predecibles. Los agujeros se alinearon. Despedirla **no resuelve** nada: era el último eslabón, los fallos latentes siguen ahí y el miedo hace que no se reporten los cuasi accidentes. Medidas: reactivar el filtro y aplicar defensa en profundidad; formación periódica con práctica (simulaciones bien comunicadas); auditar la carga de trabajo; rediseñar la política de contraseñas; crear un canal para notificar cuasi accidentes sin castigo.
3. Se espera el modelo **de seguridad física** (cerrar la puerta, no darle la llave a un desconocido) o el **médico** (higiene, «no abras lo que no conoces», responsabilidad colectiva), porque se apoyan en experiencias que ya tienen (Camp, 2009: las metáforas aprovechan atajos mentales; los datos técnicos o la exageración no funcionan). Limitación de la física: lo digital se copia sin presencia física y la «puerta» no se ve. Limitación del médico: hay que respetar la autonomía. Descartar el **de guerra**: asusta y deja la responsabilidad a los «expertos». Clave: el modelo se elige **según el público**.
4. Saber no basta: el comportamiento nuevo debe instalarse en la **memoria de largo plazo** y competir con el hábito existente. Tener muchas credenciales con reglas distintas causa **fatiga de seguridad**: la tarea **habilitadora** compite con la de **producción**. **Fogg**: puede haber motivación, pero falta **capacidad** (es difícil recordar muchas contraseñas) o un **disparador**. **Sesgo de optimismo**: «a mí no me va a pasar» (y sí pasa: credential stuffing). **Agotamiento del ego**: sin recordatorios se pierde el hábito. Solución usable: adaptar la tarea al humano con un gestor de contraseñas, SSO para reducir credenciales, *passkeys*/passwordless, y MFA solo ante actividad inusual.
5. Riesgos: **sesgo de optimismo** («no somos interesantes»); la VLAN plana permite el **movimiento lateral** con una identidad comprometida; MFA por SMS expuesta a **SIM swapping**; falla de la fase **Leaver** (cuentas fantasma, la de administrador es crítica); ventas con acceso al firewall viola el **mínimo privilegio**; riesgo de **credential stuffing** y de venta de credenciales por intermediarios. Mitigación: migrar a **Zero Trust** de forma gradual (nunca confíes, siempre verifica; acceso por sesión; microsegmentación y NAC); proceso **JML** con evento de salida RH → TI, revocar primero los privilegios y confirmar que no quede nada activo; **RBAC** (ventas ve clientes pero no toca el firewall) o **ABAC** para decisiones finas; **passkeys FIDO** con llave física en lugar de SMS; **ISPM** para detectar cuentas inactivas y administradores ocultos; auditoría continua.